
CABINET DE CONSEIL ALPHA

Client : Techsud

RAPPORT

Equipe	Equipe IPSSI
Membres	1. MAURO Enzo 2. DELMOTTE Ilona 3. PAVELESCU Alexandru 4. FERRI Romain 5. BAHNAS Layan
Date de remise	17/04/2026
Version	1.0

1. Synthèse executive

L'infrastructure de TechSud présentait plusieurs vulnérabilités critiques ayant permis la compromission partielle du système, notamment au niveau des services exposés, de la sécurité applicative et de l'absence de mécanismes de détection efficaces.

Les risques les plus importants identifiés concernent l'exécution de code à distance via un système d'upload non sécurisé (webshell), l'exposition initiale de la base de données MariaDB sur le réseau, ainsi que la présence de failles applicatives telles que l'injection SQL et le Cross-Site Scripting (XSS). Ces vulnérabilités pouvaient entraîner un accès non autorisé aux données, une compromission complète du serveur et une atteinte à la confidentialité des informations.

Des mesures correctives ont été mises en œuvre immédiatement, incluant le durcissement des accès SSH, la restriction des services réseau via pare-feu, la sécurisation des requêtes SQL, le blocage de l'exécution de scripts dans les zones sensibles et l'ajout de protections côté application. Par ailleurs, des mécanismes de détection ont été introduits grâce à l'analyse des logs et à l'automatisation des contrôles de sécurité.

Cependant, certains risques résiduels subsistent, notamment liés à l'absence de chiffrement des communications web (HTTP) et à un niveau de supervision encore limité.

Dans une perspective de mise en conformité et de sécurisation durable, les priorités sont :

- la mise en place immédiate du protocole HTTPS avec certificat valide,
- le renforcement de la supervision (centralisation des logs / SIEM),
- et l'application rigoureuse des mises à jour de sécurité.

Sans ces actions, TechSud resterait exposée à des attaques pouvant compromettre la confidentialité des données et engager sa responsabilité au regard du RGPD.

2. Contexte et périmètre audité

2.1 Contexte

Dans le cadre du projet AEGIS, la PME fictive TechSud a subi une compromission de son système d'information, mettant en évidence plusieurs failles de sécurité critiques. L'entreprise a mandaté une équipe d'audit afin d'analyser l'incident, identifier les vulnérabilités exploitées et mettre en œuvre des mesures correctives adaptées.

L'objectif principal de la mission était double : d'une part sécuriser l'infrastructure existante, et d'autre part produire un rapport d'audit détaillé permettant d'évaluer le

niveau de sécurité et de proposer des recommandations conformes aux bonnes pratiques, notamment au regard du RGPD.

Les travaux ont été réalisés dans un contexte pédagogique simulant une intervention réelle en entreprise, avec une répartition des rôles entre auditeur, administrateur système et responsable sécurité.

2.2 Périmètre audité

Le périmètre de l'audit couvre l'ensemble des composants critiques du système d'information de TechSud, incluant :

Infrastructure système

- Serveur Linux (Ubuntu 24.04)
- Service SSH (accès distant)
- Gestion des utilisateurs et des privilèges

Sécurité réseau

- Pare-feu UFW (filtrage des accès)
- Protection contre les attaques par brute force (Fail2ban)
- Analyse des ports ouverts et exposition des services

Base de données

- Serveur MariaDB
- Gestion des comptes utilisateurs et des droits
- Sécurisation des accès (local vs distant)

Application web

- Serveur Nginx avec PHP
- Gestion des fichiers uploadés
- Vulnérabilités applicatives (SQL Injection, XSS, exécution de code)

Journalisation et détection

- Logs système (auth.log, syslog)
- Logs web (requêtes HTTP, erreurs)
- Analyse des événements de sécurité

Automatisation et supervision

- Script Python d'analyse des logs
- Script Bash d'audit de sécurité
- Mise en place d'une exécution automatique via cron

2.3 Limites du périmètre

L'audit ne couvre pas :

- Les postes utilisateurs
- L'infrastructure réseau physique complète
- Les aspects organisationnels (politiques internes, formation utilisateurs)

2.4 Objectifs de l'audit

- Identifier les vulnérabilités exploitées lors de la compromission
- Évaluer le niveau de sécurité actuel du système
- Mettre en place des mesures correctives techniques
- Automatiser les contrôles de sécurité
- Proposer des recommandations alignées avec les exigences du RGPD

Ce périmètre permet d'avoir une vision globale de la sécurité de l'infrastructure TechSud et de prioriser les actions à mettre en œuvre pour réduire les risques.

3. Vulnérabilités identifiées et criticité

L'analyse de l'infrastructure TechSud a permis d'identifier plusieurs vulnérabilités majeures ayant contribué à la compromission du système. Ces failles concernent à la fois la configuration système, l'exposition des services et la sécurité applicative. Chaque vulnérabilité a été évaluée en fonction de son impact potentiel sur la confidentialité, l'intégrité et la disponibilité des données.

3.1 Exposition du port MariaDB (3306)

Lors des premiers tests, le port 3306 du serveur MariaDB était accessible depuis l'extérieur. Cette exposition permettait à un attaquant de tenter une connexion directe à la base de données.

Impact :

- Accès non autorisé aux données sensibles (emails, informations utilisateurs)
- Possibilité de brute force sur les comptes
- Risque de suppression ou modification des données

Criticité : CRITIQUE

Cette vulnérabilité représente un risque majeur, car elle permet un accès direct à un composant critique du système sans passer par l'application web.

3.2 Vulnérabilité d'injection SQL

L'application web utilisait initialement des requêtes SQL construites dynamiquement via concaténation de chaînes de caractères, sans validation des entrées utilisateur.

Une attaque de type : ' OR '1'='1

permettait de contourner les conditions de filtrage et d'accéder à l'ensemble des données.

Impact :

- Extraction complète de la base de données
- Contournement des mécanismes d'authentification
- Atteinte à la confidentialité des données

Criticité : CRITIQUE

Cette faille est particulièrement grave car elle permet une compromission totale de la base de données avec une simple requête.

3.3 Upload de fichiers non sécurisé (Webshell)

Le système d'upload ne vérifiait pas correctement le type des fichiers envoyés. Il a été possible d'uploader un fichier PHP malveillant (webshell) permettant d'exécuter des commandes à distance.

Exemple : shell.php?cmd=whoami

Impact :

- Exécution de commandes système à distance
- Prise de contrôle complète du serveur
- Installation de backdoors

Criticité : CRITIQUE

Il s'agit de la vulnérabilité la plus grave identifiée, car elle permet un contrôle total du système.

3.4 Vulnérabilité XSS (Cross-Site Scripting)

L'application web ne filtrait pas correctement les entrées utilisateur. Il était possible d'injecter du code JavaScript exécuté directement dans le navigateur.

Exemple : `<script>alert('XSS')</script>`

Impact :

- Vol de session utilisateur
- Redirection vers des sites malveillants
- Exécution de scripts à l'insu de l'utilisateur

Criticité : ÉLEVÉE

Bien que moins critique qu'un accès serveur direct, cette faille peut compromettre les comptes utilisateurs et nuire à la réputation de l'entreprise.

3.5 Mauvaise configuration initiale de SSH

Initialement, le service SSH était exposé sur le port 22 avec authentification par mot de passe activée.

Impact :

- Attaques par brute force facilitée
- Risque d'accès non autorisé
- Compromission des comptes utilisateurs

Criticité : ÉLEVÉE

Ce type de configuration est fréquemment ciblé par des attaques automatisées.

3.6 Absence de mécanismes de détection et de supervision

Avant la mise en place des scripts d'analyse, aucune surveillance active des logs n'était réalisée.

Impact :

- Attaques non détectées
- Difficulté à identifier les intrusions
- Temps de réaction élevé en cas d'incident

Criticité : MOYENNE

Cette faiblesse n'est pas une faille directe, mais elle amplifie fortement l'impact des autres vulnérabilités.

3.7 Synthèse des vulnérabilités

Vulnérabilité	Impact principal	Criticité
Webshell upload	Contrôle total serveur	Critique
Injection SQL	Accès aux données	Critique
Port 3306 exposé	Accès base de données	Critique
XSS	Vol de session	Élevée
SSH mal configuré	Accès distant	Élevée
Absence de supervision	Détection impossible	Moyenne

L'audit met en évidence une combinaison de vulnérabilités critiques permettant à un attaquant de passer rapidement d'un accès initial à une compromission complète du système.

Le scénario d'attaque probable est le suivant :

1. Exploitation d'une faille web (SQL ou upload)
2. Accès au serveur
3. Mouvement latéral vers la base de données
4. Extraction ou destruction des données

Cette situation démontre un manque de sécurisation globale et souligne la nécessité d'une approche en profondeur ("defense in depth").

Cette analyse permet de prioriser les actions correctives afin de réduire efficacement les risques et renforcer la sécurité globale de TechSud.

4. Impact RGPD

Les vulnérabilités identifiées au sein de l'infrastructure TechSud présentent un risque direct pour la sécurité des données personnelles, ce qui engage la responsabilité de l'entreprise au regard du Règlement Général sur la Protection des Données (RGPD).

4.1 Risques sur la confidentialité des données

Plusieurs failles, notamment l'injection SQL et l'exposition initiale du port MariaDB, permettaient un accès direct aux données stockées dans la base.

Données potentiellement exposées :

- adresses email
- identifiants utilisateurs
- informations applicatives

Conséquence RGPD :

- violation de données personnelles (article 4 RGPD)
- obligation de notification à la CNIL en cas d'incident avéré (article 33)

4.2 Compromission potentielle du système (webshell)

L'exploitation d'un webshell permettait une exécution de commandes à distance, donnant à un attaquant un contrôle total sur le serveur.

Impact RGPD :

- accès illimité aux données
- altération ou suppression possible des informations
- impossibilité de garantir l'intégrité des données

Cette situation constitue un manquement grave aux principes de sécurité (article 32 RGPD).

4.3 Vulnérabilités applicatives (XSS)

La faille XSS permettait l'exécution de code malveillant dans le navigateur des utilisateurs.

Impact :

- vol de session utilisateur
- accès frauduleux à des comptes
- atteinte à la confidentialité

4.4 Absence de détection et de traçabilité

Avant la mise en place des mécanismes de logs et d'analyse, les activités malveillantes n'étaient pas surveillées.

Impact RGPD :

- incapacité à détecter une violation de données
- difficulté à prouver la conformité
- absence de traçabilité des accès

4.5 Conclusion RGPD

Les vulnérabilités identifiées montrent que TechSud ne respectait pas pleinement les exigences du RGPD en matière de sécurité des données personnelles.

Les principaux manquements concernent :

- la protection insuffisante des données
- l'absence de mesures techniques adaptées
- le manque de supervision et de détection

Ces éléments exposent l'entreprise à :

- des sanctions financières
- une perte de confiance des utilisateurs
- un impact réputationnel important

5. Plan de mesures correctives mises en place

#	Action	Priorité	Responsable	Délai	Référence
1	Restreindre l'accès MariaDB à localhost (127.0.0.1) et fermer le port 3306 en externe	URGENT	Admin système	Immédiat	Art. 32 RGPD
2	Corriger les vulnérabilités d'injection SQL via requêtes préparées	URGENT	Développeur / CTO	Immédiat	Art. 32 RGPD
3	Bloquer l'exécution de scripts dans le dossier /upload et sécuriser les uploads	URGENT	Admin système	Immédiat	Art. 32 RGPD
4	Corriger la faille XSS (filtrage des entrées avec htmlspecialchars)	Court terme	Développeur	7 jours	Art. 32 RGPD
5	Durcir la configuration SSH (port 2222, désactivation root, clé publique)	Court terme	Admin système	7 jours	ANSSI – Reco SSH
6	Mettre en place et configurer UFW (pare-feu)	Court terme	Admin système	7 jours	Art. 32 RGPD

#	Action	Priorité	Responsable	Délai	Référence
7	Déployer Fail2ban pour bloquer les attaques par brute force	Court terme	Admin système	7 jours	ANSSI – Reco sécurité
8	Mettre en place un système d'analyse des logs (script Python)	Moyen terme	Admin / Sécurité	30 jours	Art. 32 RGPD
9	Automatiser les contrôles de sécurité (script Bash + cron)	Moyen terme	Admin système	30 jours	Art. 32 RGPD
10	Mettre en place HTTPS avec certificat valide (Let's Encrypt)	Moyen terme	Admin système	30 jours	Art. 32 RGPD
11	Mettre à jour régulièrement le système et corriger les failles connues	Moyen terme	Admin système	30 jours	Art. 32 RGPD
12	Mettre en place une supervision centralisée (SIEM type Wazuh)	Long terme	Responsable sécurité	90 jours	ANSSI – Détection
13	Réaliser un test d'intrusion (Pentest) régulier	Long terme	Expert externe	90 jours	Art. 32 RGPD
14	Formaliser une politique de sécurité et procédures d'incident	Long terme	DSI / RSSI	90 jours	RGPD global

6. Analyse des logs et détection

Dans le cadre de l'audit, une analyse approfondie des journaux système et applicatifs a été réalisée afin d'identifier les tentatives d'intrusion et de comprendre les vecteurs d'attaque utilisés.

6.1 Analyse des logs SSH

Les logs situés dans /var/log/auth.log ont permis d'identifier :

- plusieurs tentatives de connexion échouées depuis des adresses IP externes

- des attaques par brute force ciblant le compte utilisateur
- des connexions réussies via authentification par clé publique

Exemple observé :

- *Failed password* → tentative d'accès échouée
- *Accepted publickey* → connexion autorisée

Ces éléments démontrent que le serveur était exposé à des attaques automatisées, nécessitant la mise en place de protections renforcées.

6.2 Analyse des logs web

L'analyse des requêtes HTTP a révélé plusieurs comportements malveillants :

- tentatives de path traversal (../etc/passwd)
- injections SQL (UNION SELECT)
- attaques XSS (<script>alert()</script>)
- accès à des pages inexistantes (404)

Ces attaques ont été générées depuis une machine attaquante et correctement enregistrées dans les logs.

6.3 Détection automatisée

Un script Python a été développé afin d'automatiser l'analyse des logs et produire un rapport structuré contenant :

- les tentatives SSH échouées par adresse IP
- les connexions réussies
- les commandes sudo exécutées
- les requêtes HTTP suspectes
- les codes d'erreur (4xx, 5xx)
- les User-Agents inhabituels

Cette automatisation permet d'identifier rapidement les comportements anormaux et d'améliorer la réactivité en cas d'incident.

7. Automatisation et supervision

Afin d'assurer un niveau de sécurité constant dans le temps, des mécanismes d'automatisation et de supervision ont été mis en place sur l'infrastructure TechSud.

7.1 Script d'audit système

Un script Bash a été développé afin de vérifier automatiquement les principaux éléments de sécurité du système, notamment :

- l'état du pare-feu UFW
- le fonctionnement du service Fail2ban
- la configuration SSH (port, root, authentification)
- l'exposition de la base de données MariaDB
- les ports ouverts
- la présence de mises à jour de sécurité

Le script fournit un retour clair sous forme d'indicateurs :

- [OK] : configuration conforme
- [FAIL] : anomalie détectée

Cela permet d'identifier rapidement les points faibles du système.

7.2 Automatisation via cron

Afin de garantir une surveillance continue, le script est exécuté automatiquement à intervalles réguliers grâce à une tâche planifiée (cron).

Les résultats sont enregistrés dans le fichier :

`/var/log/audit_auto.log`

Cette approche permet :

- une vérification régulière sans intervention humaine
- une traçabilité des contrôles effectués
- une détection rapide des dérives de configuration

7.3 Supervision des logs

En complément, un script Python a été mis en place pour analyser automatiquement :

- les logs SSH (authentification, tentatives d'accès)
- les logs web (requêtes suspectes, erreurs HTTP)

Ce script permet d'identifier :

- les tentatives de brute force
- les requêtes malveillantes (SQL, XSS, LFI)
- les comportements anormaux

7.4 Limites actuelles

Bien que ces mécanismes apportent une première couche de supervision, certaines limites subsistent :

- absence de centralisation des logs
- pas de corrélation avancée des événements
- absence d'alertes en temps réel

L'automatisation mise en place constitue une base solide pour la supervision du système.

Elle permet d'améliorer la détection des incidents et de garantir un suivi régulier de la sécurité.

Cependant, une solution plus avancée (type SIEM) reste recommandée pour une surveillance complète.

8. Recommandations techniques

Au-delà des mesures correctives déjà mises en place, plusieurs actions complémentaires sont recommandées afin de renforcer durablement la sécurité de l'infrastructure TechSud.

- Mettre en place HTTPS avec certificat valide afin de sécuriser les communications
- Déployer une solution de supervision avancée (SIEM) pour centraliser et analyser les logs
- Mettre en place une authentification multi-facteurs (MFA) pour les accès sensibles
- Automatiser les mises à jour de sécurité
- Réaliser des tests d'intrusion réguliers

Ces recommandations s'inscrivent dans une démarche d'amélioration continue et visent à anticiper les menaces futures.

9. Conclusion

L'audit de sécurité réalisé sur l'infrastructure TechSud a permis d'identifier plusieurs vulnérabilités critiques ayant conduit à la compromission du système.

Les principales failles concernaient :

- la sécurité applicative (SQL, XSS, upload)
- l'exposition des services
- l'absence de supervision

Les mesures correctives mises en place ont permis de réduire significativement les risques, notamment par :

- le durcissement des accès
- la sécurisation des services
- la mise en place de mécanismes de détection

Cependant, la sécurité d'un système d'information repose sur une amélioration continue. Il est essentiel pour TechSud de maintenir ses efforts en matière de supervision, de mise à jour et de conformité réglementaire.

Enfin, cet audit démontre qu'une approche globale combinant technique, organisation et conformité est indispensable pour garantir la protection des données et la résilience du système d'information.

10. Annexes

Cette section regroupe les éléments complémentaires permettant d'illustrer les analyses réalisées lors de l'audit. Elle comprend notamment les aspects théoriques liés à la sécurité ainsi que les preuves visuelles des vulnérabilités identifiées et corrigées.

10.1 Cryptographie appliquée à TechSud (Réponse des questions du TP complémentaire)

Dans le cadre du projet, une analyse des mécanismes cryptographiques utilisés a été réalisée afin de mieux comprendre leur rôle dans la sécurisation des accès et des communications.

10.1.1 Clé SSH vs mot de passe

Une clé SSH RSA 4096 bits est beaucoup plus sécurisée qu'un mot de passe classique. Un mot de passe peut être deviné ou testé automatiquement par des attaques de type brute force, surtout s'il est faible ou réutilisé.

À l'inverse, une clé SSH repose sur un système de cryptographie asymétrique :

- une clé privée (gardée secrète sur le poste client)
- une clé publique (installée sur le serveur)

Le chiffre 4096 bits correspond à la taille de la clé, c'est-à-dire à la complexité mathématique utilisée pour le chiffrement.

Concrètement, cela signifie qu'il existe un nombre extrêmement élevé de combinaisons possibles, rendant toute tentative de cassage irréaliste avec les moyens actuels.

De plus, la clé privée ne transite jamais sur le réseau, ce qui réduit fortement les risques d'interception.

10.1.2 Fonctionnement du handshake SSH

Lorsqu'un client se connecte à un serveur SSH :

1. Le client contacte le serveur et récupère sa clé publique
2. Il vérifie l'identité du serveur (protection contre les attaques de type "man-in-the-middle")
3. Client et serveur négocient les algorithmes de chiffrement
4. Une clé de session est générée via un échange sécurisé
5. Toutes les communications sont ensuite chiffrées

Ainsi, même en cas d'interception du trafic, les données restent inexploitable.

10.1.3 HTTP vs HTTPS (vision attaquant)

Avec HTTP, les données circulent en clair.

Un attaquant utilisant Wireshark peut facilement observer :

- les identifiants
- les requêtes
- les données échangées

Avec HTTPS :

- les données sont chiffrées via TLS
- le contenu devient illisible sans la clé de déchiffrement

HTTPS garantit donc la confidentialité et l'intégrité des échanges.

10.1.4 Certificat auto-signé vs certificat signé

Un certificat auto-signé est généré par le serveur lui-même.

Il permet le chiffrement, mais n'est pas reconnu comme fiable par les navigateurs.

Un certificat signé par une autorité de certification (CA) permet :

- de garantir l'identité du serveur
- d'éviter les alertes de sécurité
- d'instaurer la confiance utilisateur

Pour TechSud, l'utilisation d'un certificat signé (ex : Let's Encrypt) est recommandée.

10.2 Captures d'écran (preuves techniques)

Les captures suivantes illustrent les différentes étapes de l'audit et les vulnérabilités identifiées :

```
techsud@techsud:~$ grep -E "^(Port|PermitRootLogin|PasswordAuthenticatio
n|PubkeyAuthentication|AuthorizedKeysFile)" /etc/ssh/sshd_config
Port 2222
PermitRootLogin no
PubkeyAuthentication yes
PasswordAuthentication no
```

La configuration SSH montre un durcissement des accès avec un port non standard, la désactivation de l'accès root et l'authentification par mot de passe, réduisant fortement les risques d'attaque brute force.

```
techsud@techsud:~/ssh$ sudo fail2ban-client status sshd
[sudo] password for techsud:
Status for the jail: sshd
|- Filter
| |- Currently failed: 0
| |- Total failed: 5
| \- Journal matches: _SYSTEMD_UNIT=sshd.service + _COMM=sshd
\ - Actions
  |- Currently banned: 1
  |- Total banned: 1
  \- Banned IP list: 192.168.1.35
```

Fail2ban détecte les tentatives de connexion échouées et bannit automatiquement les adresses IP malveillantes, limitant efficacement les attaques par brute force.

```
techsud@techsud:~$ groups adminuser
adminuser : adminuser sudo users
techsud@techsud:~$ groups appuser
appuser : appuser users
```

La séparation des privilèges entre utilisateurs permet de limiter les droits d'accès, appliquant le principe du moindre privilège et réduisant les risques en cas de compromission.


```

MariaDB [(none)]> CREATE DATABASE techsud_db;
Query OK, 1 row affected (0,000 sec)

MariaDB [(none)]> CREATE USER 'appuser'@'localhost' IDENTIFIED BY 'MotDePasseFort123!';
Query OK, 0 rows affected (0,001 sec)

MariaDB [(none)]> GRANT SELECT, INSERT, UPDATE ON techsud_db.* TO 'appuser'@'localhost';
Query OK, 0 rows affected (0,001 sec)

MariaDB [(none)]> FLUSH PRIVILEGES;
Query OK, 0 rows affected (0,001 sec)

```

Un utilisateur dédié avec des droits limités a été créé pour l'application, évitant l'utilisation du compte root et réduisant l'impact potentiel d'une compromission.

```

(enzo@kali)-[~]
$ nmap -sV -p 3306 192.168.1.44
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-15 10:39 CEST
Nmap scan report for 192.168.1.44
Host is up (0.0097s latency).

PORT      STATE SERVICE VERSION
3306/tcp  open  mysql   MariaDB 10.3.23 or earlier (unauthorized)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.74 seconds

```

Le scan réseau révèle que le port 3306 (MariaDB) était accessible depuis l'extérieur, exposant la base de données à des attaques potentielles.

```

(enzo@kali)-[~]
$ nmap -sV -p 3306 192.168.1.44
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-15 10:41 CEST
Nmap scan report for 192.168.1.44
Host is up (0.0098s latency).

PORT      STATE SERVICE VERSION
3306/tcp  closed mysql

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.72 seconds

```

Après correction, le port MariaDB n'est plus accessible depuis l'extérieur, limitant l'accès à la base de données au seul serveur local.

```

--- AUDIT MARIADB ---
Port 3306 exposé      : NOK
Root avec mot de passe : OK
Base 'test' présente  : NOK
Comptes sans mot de passe: 1
- mariadb.sys@localhost

```

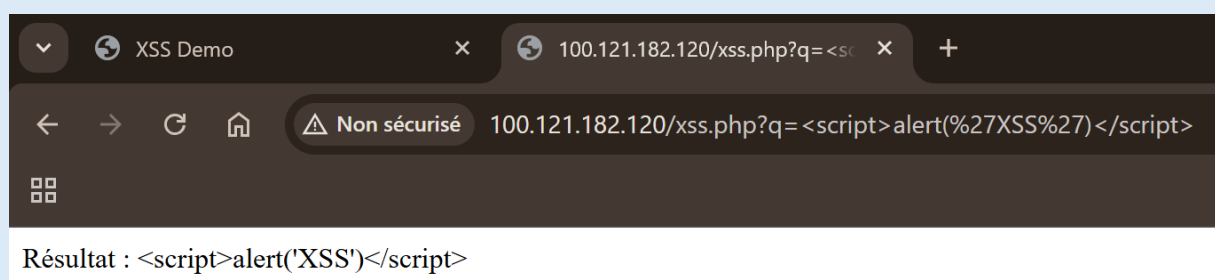
L'audit met en évidence les points de sécurité de MariaDB, notamment la non-exposition du port et l'absence de base de test, tout en identifiant des comptes systèmes spécifiques.

```
techsud@techsud:~$ curl -I http://192.168.1.44
HTTP/1.1 403 Forbidden
Server: nginx
Date: Wed, 15 Apr 2026 22:03:06 GMT
Content-Type: text/html
Content-Length: 146
Connection: keep-alive
X-Frame-Options: DENY
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
```

Les en-têtes de sécurité HTTP (X-Frame-Options, X-Content-Type-Options, X-XSS-Protection) renforcent la protection contre les attaques web courantes.

```
techsud@techsud:~$ sudo ./audit.sh | sudo tee -a /var/log/audit_auto.log
===== AUDIT SYSTEME =====
[OK] UFW actif
[OK] Fail2ban actif
[OK] SSH non sur 22
[OK] Root SSH désactivé
[OK] MariaDB local uniquement
[FAIL] Updates sécurité
```

Le script d'audit permet de vérifier automatiquement l'état de sécurité du système et d'identifier rapidement les anomalies, comme l'absence de mises à jour.



La vulnérabilité XSS permet l'exécution de code JavaScript dans le navigateur, pouvant conduire au vol de session ou à la manipulation de contenu.

```
0.121.32.102 techsud
2026-04-15T22:53:40.387225+00:00 techsud sshd[22789]: Failed password fo
r techsud from 100.121.32.102 port 56022 ssh2
2026-04-15T22:53:45.425514+00:00 techsud sshd[22789]: Failed password fo
r techsud from 100.121.32.102 port 56022 ssh2
2026-04-15T22:53:50.463056+00:00 techsud sshd[22789]: Failed password fo
r techsud from 100.121.32.102 port 56022 ssh2
2026-04-15T22:53:51.710906+00:00 techsud sshd[22789]: Connection closed
by authenticating user techsud 100.121.32.102 port 56022 [preauth]
```

Les logs montrent des tentatives répétées de connexion SSH échouées, caractéristiques d'une attaque par brute force.

Ces éléments constituent des preuves concrètes des tests réalisés et des corrections appliquées.

10.3 Références techniques

Les scripts développés dans le cadre du projet (audit système, analyse des logs, détection des anomalies) sont disponibles sur un dépôt GitHub dédié.

Lien du dépôt :

<https://github.com/Enzo-MAURO/AEGIS-BTC28.1>

Ces scripts permettent :

- d'automatiser les contrôles de sécurité
- de détecter les comportements suspects
- de générer des rapports d'audit

10.4 Conclusion des annexes

Les annexes complètent le rapport en apportant :

- une compréhension des mécanismes de sécurité utilisés
- des preuves visuelles des vulnérabilités
- des outils techniques réutilisables

Elles permettent ainsi de renforcer la crédibilité et la transparence de l'audit réalisé.